BUSINESS ASSOCIATE
Privacy and Security Program Questionnaire

University
Health System

Business Associate agrees to implement a comprehensive written privacy and security program that includes administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of ePHI that it creates, receives, maintains, or transmits on behalf of University Health System in compliance with the HIPAA Omnibus Rule.

At a minimum, Business Associate's written privacy and security program addresses the following issues.

Administrative Safeguards		YES	NO	Comments
1	**Security management process:** What date was the latest security risk assessment completed?		X	Security assessment are performed internally prior to every software release. 3rd party security assessment is scheduled for Q2-Q3 2019.
2	**Security management process:** Has the organization implemented security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level?	X		In process of enhancing internal procedure to meet expanding requirements.
3	**Security management process:** Does the organization have in place a process to apply appropriate sanctions against work force members who fail to comply with security policies and procedures?	X		
4	**Security management process:** Has the organization implemented processes to regularly review records of system activity (e.g., audit logs, access reports, and security incident tracking reports)?	X		
5	**Assigned security responsibility:** Does the organization have an identified security official/officer who is responsible for the development and implementation of security policies and procedures?	X		
6	**Work force security:** Has the organization implemented processes for the authorization and supervision of work force members who work with ePHI or in locations where it might be accessed?	X		Customer ePHI is only accessed by support personnel when accessing customer system on service calls.
7	**Work force security:** Does the organization have in place work force clearance screening steps prior to bringing someone new into the organization and allowing access to ePHI?	X		
8	**Work force security:** Does the organization have in place a process to terminate access to ePHI upon termination of employment?	X		

9	**Information access management:** Has the organization developed practices for granting access to ePHI?	X		
10	**Information access management:** Does the organization have in place practices to establish, document, review, and modify user access to ePHI?	X		
11	**Security awareness & training:** Has the organization implemented a security awareness and training program for all members of the work force?	X		
Administrative Safeguards		**YES**	**NO**	**Comments**
12	**Security awareness & training:** Does the organization have in place procedures for guarding against, detecting, and reporting malicious software?	X		
13	**Security awareness & training:** Has the organization implemented procedures for monitoring login attempts and reporting discrepancies?	X		
14	**Security awareness & training:** Does the organization have procedures in place for creating, changing and safeguarding passwords?	X		
15	**Security incident procedures**: Does the organization have in place policies and procedures to address security incidents?	X		
16	**Contingency plan:** Has the organization established a plan, policies, or procedures for responding to an emergency or other occurrence that may damage systems that contain ePHI?	X		
17	**Contingency plan:** Does the organization have a process to create and maintain retrievable exact copies of ePHI (data backup)?		X	PeriGen does not store, transfer or record ePHI from customers. ePHI always remains on customer servers.
18	**Contingency plan:** Does the organization have procedures to restore any loss of data (disaster recovery plan)?	X		
19	**Contingency plan:** Has the organization established procedures to enable continuation of critical business processes for protection of the security of ePHI while operating in an emergency mode?	X		As stated above, no customer ePHI is accessed, copied or transferred to the PeriGen corporate network. Business continuity procedure are in effect to be able to continue to provide service to customers.
20	**Contingency plan:** Does the organization periodically test and revise the disaster recovery/contingency plan?	X		
21	**Contingency plan:** Has the organization addressed the criticality of specific applications and data in support of other contingency plan components?	X		

22	**Evaluation:** Does the organization perform a periodic technical and nontechnical evaluation based initially on the HIPAA Security Rule standards, in response to environmental or operational changes affecting the security of ePHI?	X		
23	**Business associate contracts & other arrangements:** Does the organization have in place a process to manage business associate arrangements and agreements?	X		
Physical Safeguards		YES	NO	Comments
1	**Facility access controls:** Does the organization have in place policies and procedures to limit physical access to ePHI systems and the locations in which they are housed, while ensuring access by properly authorized staff?	X		
2	**Facility access controls:** Has the organization established procedures that allow access into support information systems in the event of an emergency (as part of the disaster plan)?		X	There are few designated administrators with access to critical systems
3	**Facility access controls:** Does the organization have in place policies and procedures to safeguard the facility and the equipment therein from unauthorized physical access, tampering, and theft?	X		
4	**Facility access controls:** Does the organization have in place procedures to control and validate a person's access to the facility based on role or function, including visitor control, and control of access to software programs for testing and revision?	X		
Physical Safeguards		YES	NO	Comments
5	**Facility access controls:** Does the organization have policies and procedures in place to ensure documentation of repairs and modifications to the physical components of the facility that are related to security (e.g., hardware, walls, doors, locks, etc.)		X	
6	**Workstation use:** Has the organization established policies and procedures that specify the proper functions to be performed, the manner in which those functions should be performed, and the physical attributes of the surroundings of a specific workstation or class of workstation that can access ePHI?		X	Only designated support personnel have access to customer remote access systems via SecureLink.
7	**Workstation Security:** Has the organization implemented physical safeguards for all workstations that access ePHI to restrict unauthorized users?	X		
8	**Device & media controls:** Does the organization have in place policies and procedures that govern the receipt and removal of hardware and electronic media that contain ePHI in and out of the facility?		X	Not applicable. No ePHI is stored by PeriGen.
9	**Device & media controls:** Has the organization implemented policies and procedures to address the final disposition of ePHI and/or the hardware or electronic media on which it is stored?		X	Not applicable. No ePHI is stored by PeriGen.
10	**Device & media controls:** Has the organization implemented procedures for removal of ePHI from electronic media before the media are made available for reuse?		X	Not applicable. No ePHI is stored by PeriGen.

11	**Device & media controls:** Does the organization maintain a record of the movements of hardware and electronic media and persons responsible for its control?		X	Not applicable. No ePHI is stored by PeriGen.
12	**Device & media controls:** Does the organization have in place a process to create a retrievable, exact copy of ePHI when needed (data backup)?		X	Not applicable. No ePHI is stored by PeriGen.
Technical Safeguards		YES	NO	Comments
1	**Access controls:** Has the organization implemented technical policies and procedures for electronic information systems that maintain ePHI to allow access to those persons or software programs that have been granted access rights?	X		
2	**Access controls:** Does the organization assign a unique user ID for identifying and tracking user identity?	X		
3	**Access controls:** Does the organization have in place a process to allow access to necessary ePHI in the event of an emergency?		X	Not applicable
4	**Access controls:** Does the organization have in place procedures that terminate an electronic session after a predetermined time of inactivity (automatic logoff)?	X		
5	**Access control:** Has the organization implemented a mechanism to encrypt and decrypt ePHI as necessary?	X		
6	**Audit controls:** Does the organization have in place mechanisms to examine/audit activity in hardware and software systems that contain or use ePHI?	X		Those controls are embedded in the software that is installed at the hospital where ePHI is accessed and stored.
Technical Safeguards		YES	NO	Comments
7	**Integrity:** Does the organization have in place policies and procedures to protect ePHI from improper alteration or destruction?		X	Not applicable
8	**Person or entity authentication:** Does the organization have in place procedures to verify that a person or entity seeking access to ePHI is the one claimed?	X		Only limited to Windows access controls to the restricted Operations team who has access to remote control sessions to hospitals.
9	**Transmission security:** Has the organization implemented technical security measures to guard against unauthorized access to ePHI that is being transmitted over an electronic communications network?	X		Access to customer network and servers is governed by the SecureLink service (or the service

				mandated by the customer)
10	**Transmission Security:** Has the organization implemented a process to encrypt ePHI whenever deemed appropriate?	X		That said, no ePHI is transferred or stored at PeriGen
Privacy – General		YES	NO	Comments
1	Are your Notice of Privacy Practices posted in lobbies and key areas; available for distribution to new patients? (where applicable)		X	Not applicable
2	Is there a privacy concern/complaint process in place?		X	Not applicable
3	Are there system wide privacy policies implemented?	X		
4	Does orientation for new employees cover privacy and security practices?	X		
5	Are privacy and security compliance issues reported to the organization's leadership?	X		
6	Are disposal and destruction practices consist with federal requirements	X		Policies and training cover disposal/destruction but in practice not applicable since no PHI is stored at PeriGen.
7	Are there subcontract agreements used in this engagement?	X		
8	Is there a process in place to monitor subcontract agreements used for UHS ePHI?		X	
9	Does your organization use offshore subcontractors?	X		
10	Will offshore subcontractors be used for UHS ePHI?		X	

I hereby certify that the information provided herein, is true and correct and that I have the right and/or authority to complete this Privacy and Security Questionnaire.

Bruno Bendavid
Printed Name

Signature

MARCH 25, 2019
Date

Approved By:

Joshua H. Nieto, General Counsel
Chief Compliance/HIPAA Officer

Date